REVUE DE PRESSE HEBDOMADAIRE

Software Compliance

L'essentiel de la conformité des logiciels embarqués dans les produits de défense

N° 6 – Mardi 10 novembre 2026

Revue de presse hebdomadaire, tous les mardis

Les autorités européennes rappellent aux fabricants la déclaration du CRA après le sabotage de systèmes de réfrigération, que la France attribue à l'Iran ; une faille d'OpenSSH propre aux systèmes embarqués est activement exploitée ; le BIS prolonge jusqu'au 10 janvier 2027 la suspension de la règle des affiliés ; la directive sur les transferts intra-UE de produits de défense est publiée.

DANS CE NUMÉRO

SBOM et normes 1
Outils 2
Chaîne d'approvisionnement 3
Commerce international 3
France et UE 3
Licences 4
Glossaire 4
Agenda 4

À LA UNE

Réfrigération sabotée, le CRA rappelé aux fabricants

Des systèmes de réfrigération ont été attaqués dans plusieurs États membres ; les autorités européennes rappellent aux fabricants leur obligation de déclarer, et la France attribue le sabotage à l'Iran.

Systèmes de réfrigération : le 4 novembre 2026, la Commission, l'ENISA, Europol, le réseau des CSIRT et EU-CyCLONe ont signalé des cyberincidents qui touchent, depuis le 11 octobre, des systèmes de réfrigération commerciaux dans plusieurs États membres ; ils rappellent que les fabricants doivent déclarer les incidents graves et les vulnérabilités activement exploitées sur la plateforme unique du CRA.

Les autorités invitent les organisations à réduire immédiatement l'exposition des systèmes concernés et à suivre les avis de leur CSIRT national. L'ENISA rassemble ces avis dans un recueil.

La déclaration distingue deux obligations. Le fabricant déclare à l'ENISA ; l'exploitant qui relève de NIS2 signale les incidents importants à son CSIRT ou à son autorité. Les principales exigences du CRA, dont la sécurité dès la conception, le support de sécurité pendant toute la durée de vie du produit et la correction des vulnérabilités sans délai, s'appliqueront le 11 décembre 2027.

Le fabricant doit pouvoir dire vite si l'un de ses produits est en cause, et qui dépose l'alerte. Des équipements dotés d'une interface d'administration accessible depuis un réseau pourraient faire l'objet d'attaques comparables.

Contrôleurs de réfrigération sabotés : la France attribue l'attaque à l'Iran

Attribution à l'Iran : le 9 novembre 2026, la France a attribué à l'Iran une campagne de sabotage qui a visé, dans la nuit du 11 au 12 octobre, les contrôleurs de réfrigération de plus de 700 sites de la grande distribution ; le CERT-FR décrit des paramètres de dégivrage modifiés et des équipements Schneider Electric ciblés.

L'attaque a causé des dégâts matériels, des incendies et des pertes de denrées estimées à plusieurs dizaines de millions d'euros. La France l'attribue à une unité liée au centre cyber du Corps des gardiens de la révolution islamique.

Le rapport du CERT-FR décrit aussi des scripts permettant de scanner, d'accéder et de contrôler des équipements industriels Schneider Electric, Siemens et Rockwell, et l'usage du protocole Modbus pour des reconnaissances massives. Des équipements Schneider Electric de petites installations hydroélectriques ont été visés en même temps. La France convoque l'ambassadeur d'Iran.

Le fabricant doit vérifier ce qu'un attaquant peut modifier à distance sur ses produits et documenter le durcissement attendu chez le client. La France proposera de nouvelles sanctions de l'UE ; si elles sont adoptées, les listes de filtrage devront suivre.

EN BREF

Plateforme unique du CRA : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

Périmètre : les déclarations CRA visent aussi les produits déjà sur le marché avant le 11 septembre et se poursuivent après la fin du support.

SBOM, NORMES ET RÉFÉRENTIELS

Vingt-trois organisations demandent la citation rapide des normes IEC 62443 au titre du CRA ; Swift produit ses SBOM à la compilation ; un projet télécom européen détaille sa préparation au CRA.

CRA : l'industrie demande la citation rapide des normes EN IEC 62443

Normes IEC 62443 : le 6 novembre 2026, 23 organisations, dont DIGITALEUROPE, ont demandé à la Commission de citer rapidement au Journal officiel les futures normes harmonisées EN IEC 62443, adaptées aux exigences du CRA, pour que le produit dans son ensemble bénéficie de la présomption de conformité.

Les signataires visent des normes construites à partir des parties IEC 62443-4-1 et 4-2, en réponse à la demande de normalisation M/606. Les normes verticales prévues couvrent des produits des classes I et II du CRA.

Leur argument tient à l'usage. La série sert depuis plus de quinze ans ; elle figure dans les schémas de certification, les

achats et les contrats de la chaîne d'approvisionnement. Une communauté nombreuse de professionnels formés et certifiés s'appuie sur elle.

Aucune norme harmonisée du CRA n'est encore citée au Journal officiel : d'ici là, le fabricant doit démontrer seul le respect des exigences essentielles. Une citation rapide permettrait de réutiliser des évaluations IEC 62443 déjà menées.

Swift : des SBOM produits par la chaîne de compilation

Swift 6.4 : selon le podcast de l'OpenSSF du 3 novembre 2026, le gestionnaire de paquets de Swift génère désormais des SBOM CycloneDX et SPDX à partir du graphe de compilation, qui sait ce qui a réellement été inclus dans le binaire ; la fonction figure aussi dans Xcode 27.

La fonction répond à la proposition SE-0509. Le graphe des paquets résolus tient compte des options activées ; le graphe de compilation sait quelles dépendances conditionnelles ont été retenues.

Les intervenants défendent un principe : le système de compilation fait foi. Reconstruire l'inventaire après coup perd forcément de l'information, et un SBOM inexact peut être pire que pas de SBOM, car il donne une fausse assurance.

Pour ses logiciels écrits en Swift, le fabricant peut obtenir un SBOM fidèle au binaire livré, à condition de compiler avec les nouveaux outils. Des clients pourraient exiger ce mode de production pour d'autres langages.

Sylva : un projet européen détaille sa préparation au CRA

Sylva : dans un billet de l'OpenSSF du 6 novembre 2026, ce projet open source européen du secteur des télécoms décrit sa préparation au CRA, SBOM générés en intégration continue avec Trivy et Dependency-Track, artefacts signés et attestés avec Sigstore ; une démarche qui n'est ni une certification ni un statut juridique.

Les signatures reposent sur cosign et des attestations in-toto. SLSA a donné au projet un vocabulaire commun et un objectif. L'intégration continue lance aussi analyse statique et linters.

Les mesures automatiques ont leurs limites. Sur des commits récents de sylva-core, environ 94 % des changements ont été relus, mais l'outil Scorecard n'en compte qu'environ 65 %.

Pour un fabricant qui intègre un tel composant, ces pratiques facilitent la diligence sans la remplacer : elle reste à sa charge. Des indicateurs automatiques pourraient sous-estimer les pratiques réelles d'un projet.

EN BREF

CycloneDX 2.0 : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

Normes du CRA : la procédure d'approbation de 17 projets de normes verticales de l'ETSI se termine d'ici mi-novembre 2026 ; ces projets visent à devenir des normes harmonisées.

OUTILS ET SERVICES DE CONFORMITÉ

cdxgen produit les premiers documents CycloneDX 2.0 ; Zarf annonce sa version 1.0 pour la livraison en milieu isolé ; Syft et OSV-Scanner publient de nouvelles versions.

cdxgen 13.7 : premiers documents CycloneDX 2.0

cdxgen 13.7 : publiée le 7 novembre 2026, cette version du générateur de SBOM sait produire, lire, signer et auditer des documents CycloneDX 2.0, en préversion de la spécification encore en attente de ratification ; le format par défaut reste 1.7.

Les environnements d'exécution installés reçoivent désormais un identifiant de paquet, ce qui rétablit la recherche de vulnérabilités sur ces composants. La version corrige aussi quatre avis de sécurité ; la branche de support long 12.9.1, publiée la veille, corrige quatre problèmes de la ligne 12.x.

CycloneDX 2.0 doit être approuvé par Ecma International en décembre ; selon le projet, les SBOM déjà en production continueront de fonctionner. Le dépôt de l'outil est désormais hébergé sous sa propre organisation.

Le fabricant peut tester le nouveau format sans changer ce qu'il livre. Des documents produits avec une préversion pourraient devoir être régénérés après la ratification.

Zarf 1.0 : livrer des logiciels en milieu isolé

Zarf 1.0 : annoncée le 9 novembre 2026 par l'OpenSSF, la version 1.0 de cet outil de livraison de logiciels en milieu isolé (*air-gapped*) stabilise le format des paquets et renforce leur signature ; le dépôt ne porte, au 10 novembre, qu'une version candidate.

Le billet est signé par un mainteneur de l'outil chez Defense Unicorns. La version 1.0 introduit un nouveau schéma de paquets, avec un guide et des outils pour convertir les paquets existants. La documentation résume le principe : développer connecté, déployer déconnecté.

Un paquet regroupe dans un fichier ce dont l'application a besoin pour une grappe Kubernetes, avec un registre et un serveur Git intégrés. L'outil y joint un SBOM produit par Syft, qui suit le paquet partout où il est déplacé. Sa génération peut être désactivée par une option : la procédure de livraison doit l'interdire.

Avant d'adopter la 1.0, le fabricant doit attendre la version définitive et prévoir la conversion de ses paquets.

Syft 1.57 : les identifiants de compilation des binaires ELF

Syft 1.57 : publiée le 5 novembre 2026, cette version du générateur de SBOM d'Anchore relève les identifiants de compilation GNU des binaires ELF et ne génère plus de CPE pour les paquets de correctifs Microsoft ; la 1.57.1 du 9 novembre met à jour des dépendances vulnérables.

La version corrige aussi des versions de préversion tronquées dans les binaires Go. La 1.57.1 met à jour des dépendances visées par des avis de sécurité, dont un avis critique sur une bibliothèque Brotli écrite en Go.

Ce relevé aide à rapprocher un binaire livré de sa compilation d'origine, utile pour les micrologiciels Linux. Des SBOM produits avec une version antérieure pourraient contenir des identifiants superflus, sources de faux positifs.

OSV-Scanner 2.7.1 : un mode hors ligne plus robuste

OSV-Scanner 2.7.1 : publiée le 9 novembre 2026, cette version du scanneur de Google poursuit l'analyse hors ligne quand la base locale d'un écosystème échoue, limite par défaut son serveur de rapports à la machine locale et signale les violations de licence des sources du système.

L'outil ne développe plus les variables d'environnement lues dans des fichiers de configuration npm non fiables.

En milieu isolé, le résultat reste à contrôler pour l'écosystème dont la base a échoué. Un serveur de rapports lancé avec une version antérieure pourrait avoir été accessible depuis le réseau local.

EN BREF

cdxgen 13.6 : depuis le 31 octobre 2026, le générateur détecte les décodeurs Brotli intégrés aux environnements d'exécution et aux binaires.

Dependency-Track 5.2.1 : depuis le 25 octobre 2026, cette version corrige un contrôle d'accès inopérant de la plateforme d'analyse de SBOM.

SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

Une faille d'OpenSSH propre aux systèmes embarqués est activement exploitée ; FreeSWITCH rejoint le même catalogue ; zlib corrige plusieurs failles.

OpenSSH : une faille exploitée sur les systèmes embarqués musl sans PAM

OpenSSH : le 9 novembre 2026, la CISA a inscrit dans son catalogue des vulnérabilités activement exploitées une faille du serveur sshd sur les systèmes Linux qui utilisent la bibliothèque C musl sans PAM, configuration courante des images embarquées ; un mot de passe très long y ouvre un compte pourtant verrouillé ; la version 10.6p2 la contourne.

Pour un compte dont le champ de mot de passe vaut « * », un mot de passe de plus de 257 caractères suffit, car la fonction crypt de musl renvoie alors « * ».

Cette configuration est courante dans les images Yocto, Buildroot et Alpine de nombreux dispositifs médicaux connectés. L'éditeur Medcrypt conseille de chercher dans le SBOM la présence de musl, la version d'OpenSSH et l'état de PAM.

Le CERT-FR recommande de désactiver l'authentification par mot de passe ou, à défaut, le service ; tout correctif exige un redémarrage de sshd. Pour un produit relevant du CRA, la vulnérabilité exploitée se déclare à l'ENISA. Un équipement dont le port SSH est accessible pourrait être ouvert à distance.

FreeSWITCH : une faille d'injection de commandes exploitée

FreeSWITCH : le 9 novembre 2026, la CISA a aussi inscrit dans son catalogue une faille de cette plateforme de téléphonie open source qui permet à un correspondant d'exécuter des commandes, y compris du système d'exploitation, par la messagerie ; elle est corrigée dans la version 1.11.3.

Selon la NVD, le choix d'un protocole de messagerie menait à la fonction d'exécution des commandes de l'outil.

L'avis du projet, publié le 28 octobre, vise les versions 1.11.2 et antérieures. En attendant la mise à jour, il propose de désactiver la messagerie ; le correctif ajoute un paramètre, désactivé par défaut, qui autorise ce protocole.

Un fabricant dont une passerelle de communication intègre ce composant doit la mettre à jour ou la durcir.

zlib 1.4 : des failles corrigées dans une bibliothèque très répandue

zlib 1.4 : annoncée le 5 novembre 2026, cette version de la bibliothèque de compression corrige notamment un débordement de tampon de gzwrite() en mode non bloquant et une écriture hors limites d'inflateGetDictionary(), qui touche les versions 1.3.1 et 1.3.2.

La faille d'inflateGetDictionary() peut écrire jusqu'à 8 Mo au-delà du tampon de 32 Ko de l'appelant.

La mise à jour n'est pas transparente : la version modifie certaines interfaces de programmation.

Le fabricant doit retrouver la bibliothèque dans ses produits, y compris les copies intégrées au code, puis tester les changements avant de passer en 1.4. Un produit qui décompresse des données reçues pourrait être exposé si l'une de ces failles venait à être exploitée.

EN BREF

Brotli : depuis le 27 octobre 2026, une faille critique du décodeur de cette bibliothèque de compression figure au catalogue des vulnérabilités exploitées de la CISA.

Noyau Linux : depuis le 28 octobre 2026, l'élévation de privilèges « Fragnesia » figure au catalogue des vulnérabilités exploitées de la CISA.

COMMERCE INTERNATIONAL

Exportations et sanctions

Le BIS prolonge jusqu'au 10 janvier 2027 la suspension de la règle des affiliés ; Singapour applique sa nouvelle liste le 1er décembre ; la révision de l'USML reste ouverte aux commentaires.

EAR : la suspension de la règle des affiliés prolongée jusqu'au 10 janvier 2027

Mise à jour, règle des affiliés du BIS : selon une règle publiée au Federal Register le 9 novembre 2026, la suspension de cette règle, qui devait prendre fin le 9 novembre, est prolongée jusqu'au 10 janvier 2027 ; la règle étendrait les restrictions de l'Entity List aux sociétés détenues à 50 % ou plus par des entités inscrites.

La règle ne donne pas de motif et ne retient pas les commentaires déjà reçus, qui serviront à des règles ultérieures. Selon les cabinets Baker McKenzie et Nixon Peabody, elle applique la prolongation de deux mois de la trêve commerciale entre les États-Unis et la Chine. La suspension d'un an avait été décidée en novembre 2025.

Pour l'industriel, l'échéance glisse sans disparaître : le filtrage des clients, distributeurs et sous-traitants doit intégrer la chaîne de détention avant cette nouvelle date. Baker McKenzie recommande de poursuivre la préparation des procédures de filtrage fondées sur la détention. Les livraisons, mises à jour logicielles et l'assistance technique relevant de l'EAR destinées à ces filiales pourraient alors exiger une licence.

EN BREF

Royaume-Uni, listes de contrôle : la mise à jour des contrôles sur les biens, logiciels et technologies militaires et *dual-use* devrait entrer en vigueur début décembre 2026.

CMMC : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

FRANCE ET UE

NIS2, défense, IA

La directive sur les transferts intra-UE de produits de défense est publiée au Journal officiel ; l'Assemblée nationale examine enfin la loi Résilience.

Transferts intra-UE de produits de défense : la directive 2026/2383 publiée

Mise à jour, Omnibus défense : la directive (UE) 2026/2383 sur la simplification des transferts intra-UE de produits de défense a été publiée au Journal officiel le 3 novembre 2026 ; les licences générales prévues pour les partenariats industriels structurés entre entreprises de plusieurs États membres s'appliqueront aussi aux transferts immatériels de logiciels et de technologie ; transposition au plus tard le 24 novembre 2027.

Le texte modifie deux directives de 2009, sur les transferts de produits liés à la défense et sur les marchés publics de défense. Il entre en vigueur le 23 novembre ; les mesures nationales s'appliqueront à partir du 24 février 2028.

Une nouvelle licence générale couvre les transferts entre entreprises certifiées. Selon la National Law Review, chaque État membre doit publier des licences

générales pour trois catégories supplémentaires. Le texte appartient à l'Omnibus défense, présenté par la Commission pour faciliter les investissements de défense.

Jusqu'à la transposition, le régime français actuel s'applique. L'industriel peut dès maintenant recenser ses transferts de logiciels et de données techniques vers ses partenaires européens et vérifier sa certification. Elle pourrait ouvrir la voie à des transferts sans licence individuelle.

Loi Résilience : l'examen en séance commence à l'Assemblée nationale

Mise à jour, loi Résilience : l'Assemblée nationale examine en séance publique, depuis le 9 novembre 2026, le projet de loi qui transpose notamment NIS2, sur le texte de sa commission spéciale ; 407 amendements ont été déposés et l'examen est prévu jusqu'au 13 novembre.

Les députés travaillent sur le texte de leur commission spéciale. Adopté par le Sénat le 12 mars 2025, le projet avait été retiré de l'ordre du jour de l'Assemblée en octobre.

Selon LCP, le nombre des entités régulées passerait de 500 à près de 15 000. Les sanctions pourraient atteindre 10 millions d'euros ou 2 % du chiffre d'affaires mondial. Une éventuelle commission mixte paritaire devra ensuite accorder les deux chambres.

L'industriel doit vérifier s'il serait entité essentielle ou importante et suivre les exigences que ses clients opérateurs pourraient lui répercuter. Les mesures de sécurité de la chaîne d'approvisionnement pourraient atteindre ses produits logiciels.

EN BREF

Responsabilité du fait des produits : la directive (UE) 2024/2853, qui couvre le logiciel, doit être transposée au plus tard le 9 décembre 2026.

AI Act, normes harmonisées : selon un compte rendu publié par le CEN-CENELEC, la demande de normalisation révisée fixe leur échéance à février 2027.

LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

OpenChain publie un cadre de SBOM pour l'automobile qui exige la licence conclue et l'avis de copyright de chaque composant ; le contentieux Vizio reste ouvert.

OpenChain : un cadre de SBOM pour la chaîne automobile

Automotive SBOM Framework 1.0 : annoncé dans la lettre d'OpenChain du 8 novembre 2026, ce cadre pour les SBOM échangés dans la chaîne d'approvisionnement automobile rend obligatoires la licence conclue et l'avis de copyright de chaque composant ; il n'impose aucun format.

Le cadre suit les spécifications générales de SBOM en les adaptant aux pratiques de l'automobile. Parmi les champs obligatoires figurent aussi le fournisseur, les relations entre composants, un identifiant unique et le nom de fichier ; la licence déclarée et le hachage restent facultatifs.

Les licences s'expriment avec les identifiants SPDX. La valeur NOASSERTION est admise quand l'information manque, mais doit rester exceptionnelle.

Le fournisseur doit pouvoir livrer la licence retenue après analyse, pas seulement celle que déclare le projet.

EN BREF

Oracle JDK 21 : depuis la version 21.0.13 du 20 octobre 2026, les mises à jour sont proposées sous licence OTN, qui ne permet pas la redistribution.

GPL, SFC contre Vizio : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

AGENDA

Dates à surveiller

NOV. 2026 — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

23 NOV. — EXPORT UE
Vingtième jour après la publication au JO du 3 novembre 2026 ; transposition au plus tard le 24 novembre 2027

30 NOV. — EXPORT ÉTATS-UNIS
Projet publié le 1er octobre 2026 : retrait de certains articles de la liste, définitions révisées, nouvelle exemption de licence

DÉC. 2026 — EXPORT SINGAPOUR
Ordonnance publiée le 1er octobre 2026, fondée sur les listes 2025 des régimes multilatéraux ; transferts électroniques de technologie compris

DÉC. 2026 — EXPORT ROYAUME-UNI
Mise à jour des listes militaire et dual-use (biens, logiciels, technologies) annoncée par l'avis aux exportateurs 2026/24

9 DÉC. — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

JANV. 2027 — EXPORT ÉTATS-UNIS
Suspension prolongée par la règle finale du BIS publiée au Federal Register le 9 novembre 2026

DÉC. 2027 — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

GLOSSAIRE

Sigles et termes cités

Brotli Bibliothèque open source de compression de données créée par Google

CERT-FR Centre gouvernemental de veille

CISA Agence américaine de cybersécurité et de sécurité des infrastructures

CRA Cyber Resilience Act

CycloneDX Standard de nomenclature des composants (BOM)

ELF Executable and Linkable Format

ENISA Agence de l'Union européenne pour la cybersécurité

FreeSWITCH Pile de téléphonie logicielle open source (voix sur IP

IEC Commission électrotechnique internationale

Kubernetes Plateforme open source d'orchestration de conteneurs

Modbus Protocole de communication industriel ancien et très répandu

musl Bibliothèque C standard légère

NOASSERTION Valeur des SBOM SPDX qui indique qu'aucune information n'est fournie

OpenChain Projet de la Linux Foundation

OpenSSH Implémentation open source du protocole SSH, client et serveur (sshd), présente dans la plupart des systèmes Linux et embarqués.

PAM Pluggable Authentication Modules

SBOM Software Bill of Materials

Sigstore Projet open source de signature et de vérification des artefacts logiciels (versions

Zarf Outil open source qui empaquette et déploie des applications Kubernetes dans des environnements isolés

zlib Bibliothèque open source de compression de données

Software Compliance
Revue de presse hebdomadaire, N° 6 du 10 novembre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), peut comporter des erreurs : pensez à croiser vos sources.
Édition en ligne avec sources : revue.dejeun.es/2026-11-10
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.